

ITT320 INTRO TO COMPUTER SECURITY

Chapter 2 : Types of Attack

Zulazeze Sahri, UiTM



Objectives

- Describe the most common computer and network attacks
- Explain how these attacks are executed
- Malware
- Denial of Service attacks
- Cyber Stalking, Fraud and Abuse
- Phishing
- Man-in-the-Middle Attack / Session Hacking
- SQL Injection / XSS Attacks
- Zero-Day-Exploit
- Buffer Overflow



Introduction to Cyber Attacks

Cyber attack hits businesses everyday. Hence, there are two types of businesses, those that have been attacked and those who don’t yet been hacked.

Cybercrime has increased every year as attacker try to take advantages to the system vulnerabilities that the companies do not aware.

Therefore, we need to keep in mind with the existing of cyber attack and threats, keep the vulnerability management in place and know how to defend our system.



Malware

Malware is the term refers to Malicious Software, that breaches computer and network through vulnerabilities, user click dangerous email attachment and links, and install risky software.

- Once you have been infected, Malware can do the following:
  - Block access to files, folders and key components of network
  - Installs other or additional harmful software (Backdoor)
  - Taking control of your machine
  - Monitor your actions and keystroke
  - Gain confidential data and send to the attacker’s home base
  - Disrupt certain system components and make system failure



Malware - Viruses

- There are number types of Malware :

  Viruses – a program that self-replicates, growth and rapidly spread and infected the entire network.

  - Most common threats to network, infected, copying itself and becoming part of the another program

  - Example of Viruses
    - Ransomware
    - Fake Windows Updates / AV
    - Gameover Zeus
    - Rombertik
    - And More..



Malware-Worm

Program that able to self-replicate and can spread copies for themselves (Modified)

Virus vs Worm – Worm operate more independently; virus depends on a host program to spread itself.

Characteristic of Worm :

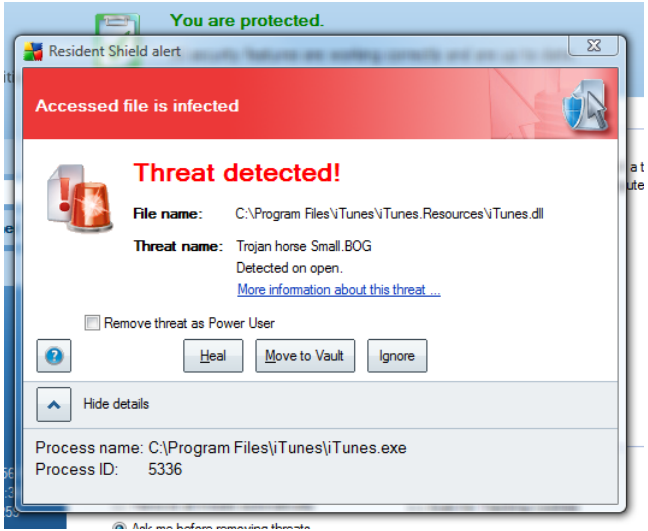
- Standalone software
- Do not require human intervention (execute) to run the attack and propagate
- Fast spread by exploit a vulnerability on the target system
- Advanced worm – encryption, wipers, and ransomware technologies to harm target

Malware-Trojan

Trojan Horses
Program that looks benign, but has malicious intent

The Trojan may cause:

- Download harmful software
- Install a key logger or other spyware
- Delete files
- Open a backdoor for hacker to use





Malware-Trojan

Example of the latest Trojan for 2020:

Symantec AntiVirus detections (1063)

These threats are also detected by the latest Virus Definitions.

A97M.Amg.Trojan	AOL 79316.Trojan	AOL Trojan 0797A (3)	AOL.Trojan.1264
A.O.M. Trojan	AOL Trojan 1	AOL Trojan 873	AOL.Trojan.1294
Abaddon Trojan	AOL Trojan 2	AOL Trojan 911	AOL.Trojan.BAT
Absturz.Trojan	AOL Trojan 3	AOL Trojan 958	AOL.Trojan.Click
Absturz.Trojan (2)	AOL Trojan 4	AOL Trojan 966	AOL.Trojan.Click (2)
Acid Rain Trojan (1)	AOL Trojan 5	AOL Trojan 1525	AOL.Trojan.Click (3)
Acid Rain Trojan (2)	AOL Trojan 6	AOL Trojan 2351	AOL.Trojan.Click (4)
Adeni.Trojan	AOL Trojan 7	AOL Trojan Winsyst	AoTaun Trojan
AIMpws.Trojan	AOL Trojan 8	AOL Trojan Winsyst 2	Avkiller.Trojan



Malware-How to

Viruses Propagate in two ways:

- Scanning computer for network connections
- Reading e-mail address book and sending to all

Protecting Against Virus Attacks:

- Always use virus scanner software
- Do not open unknown attachments
- Establish a code word with friends and colleagues
- Do not believe security alerts sent to you
- keep current with all OS and application updates and patches



Others …

Brainstorm – Take 5 and Find-Out

Cyber Stalking, Fraud and Abuse

Phishing ?

Man-In-The-Middle-Attack

Zero Day Attack

SQL Injection

XSS

OWASP TOP 10 VUL

Spyware

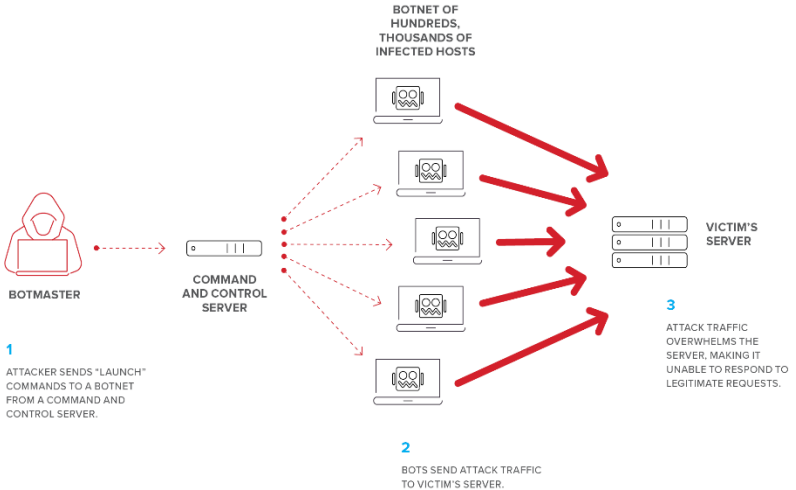
Rootkit

Denial of Services

One of most common and simplest forms of attack.

Based on the premise that all computers have operational limitations

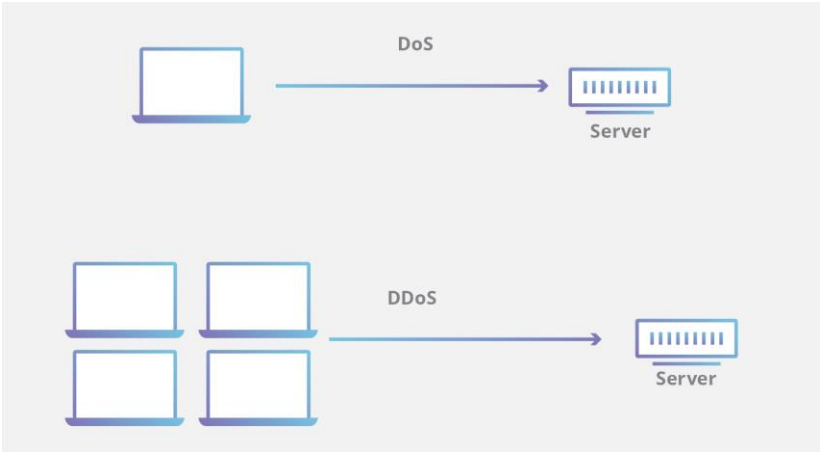
Utilizes the ping utility to execute the attack



Denial of Services

- Denial of Service (DoS) in action –to prevent legitimate access to your system / website / network (one attacker)

- Distributed Denial of Service (DDoS) – Launched from multiple attackers / Zombies / bots Multi-national / Gigabytes of data sent



Denial of Services

Types of DoS:

- SYN Flood
- Smurf Attack
- The Ping of Death
- Distributed Reflection Denial of Service

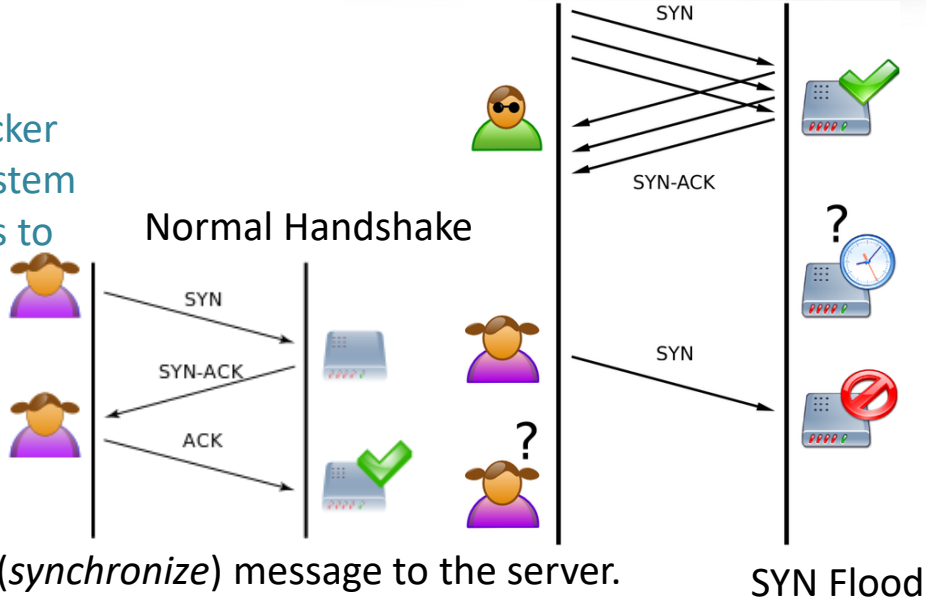


Denial of Services

SYN Flood

A form of denial-of-service attack in which an attacker sends a succession of SYN requests to a target's system in an attempt to consume enough server resources to make the system unresponsive to legitimate traffic

Takes advantage of the TCP handshake process



3-way TCP handshake:

1. The client requests a connection by sending a SYN (*synchronize*) message to the server.
2. The server *acknowledges* this request by sending SYN-ACK back to the client.
3. The client responds with an ACK, and the connection is established.

Denial of Services

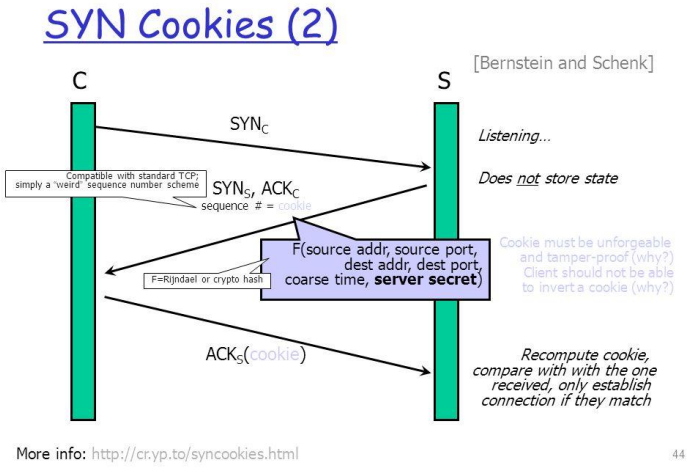
SYN Flood

A properly configured firewall can prevent the SYN flood attack.

The basic defensive techniques are as follows:

- Micro Blocks -
- SYN Cookies
- RST Cookies
- Stack tweaking

https://youtu.be/sLbihU82x7s



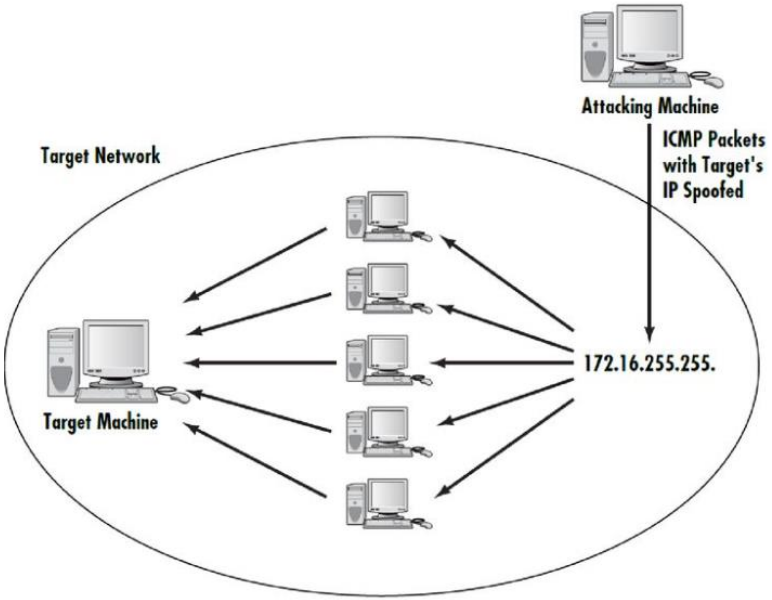
Denial of Services

Smurf Attack

The attacker first sends an ICMP echo request packet to the intermediary's IP broadcast addresses. The intermediary's network will receive this request packet and will send an ICMP echo reply packet back and cause the network congested and outages

Very popular attack Utilizes the ICMP packet to execute the attack

Graphic to the right illustrates this type of attack



Denial of Services

The Ping of Death

Attacks machines that cannot handle

oversized packets → cause the victim's system crash



How to attack?

1. Sends a large number of ICMP ECHO Request or ping packets to the victim.
2. The victim responds with ICMP Echo Reply packets
3. Both the victim's incoming and outgoing bandwith are used

Example : ping x.x.x.x –l 64000 –w 0 -t

Denial of Services

The Ping of Death

Two Types of PoD:

UDP Flood

- Variation to the PoD that targets open ports
- Faster due to no acknowledgements required
- Sends packets to random ports
- If enough are sent, the target computer shuts down



TCP Flood

Another name for the ping flood

Denial of Services

The Ping of Death

How to mitigates ?

- ✓ Ensure that systems are patched and up to date
- ✓ Most current operating systems automatically dr oversized packets



Denial of Services

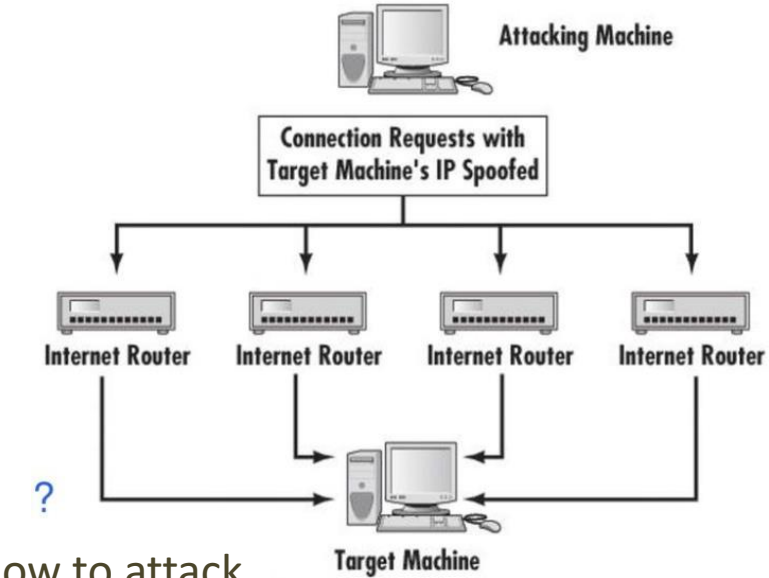
Distributed Reflection Denial of Services

Special kind of DoS

- Uses Routers to execute the DoS attack
- Routers do not have to be compromised in order to execute the attack

Mitigation ?

- Configure routers to not forward broadcast packet

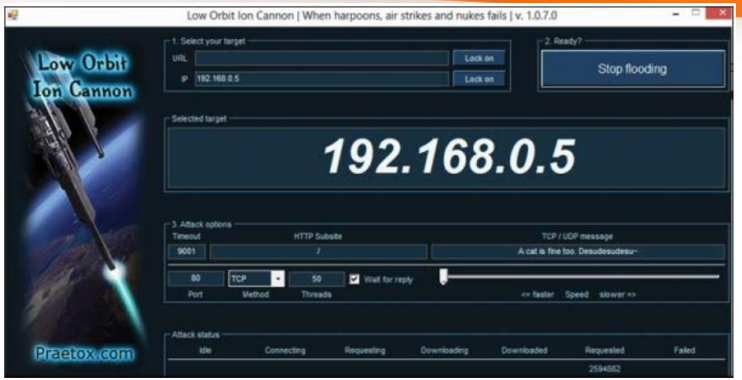


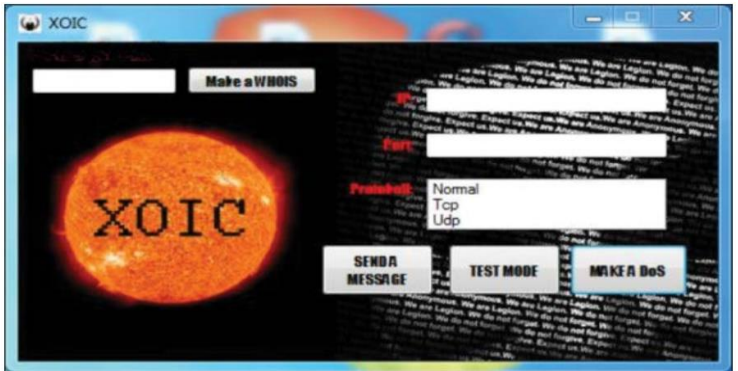
How to attack

Denial of Services

DoS Tools

- Tools are downloadable from the Internet
- Ease of access facilitates widespread use
- Most prevalent:
  - Low Orbit Ion Cannon – TCP, UDP, HTTP Flooding
  - XOIC
    - 3 Modes : Send Message, Execute Brief Test, DoS Attack
    - put in the target URL or IP address and then begin the attack.
  - Tribal Flood Network (TFN2K)
    - Used in UDP, ICMP, and TCP SYN Flood attacks

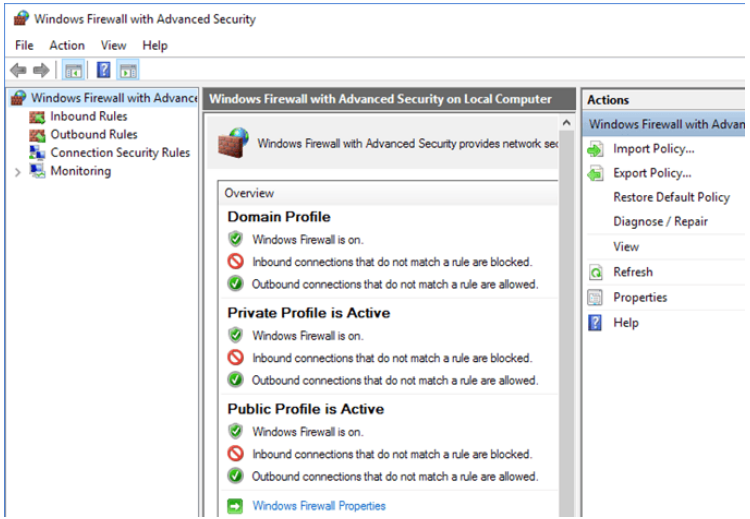




Denial of Services

How to Defend Against DoS Attack

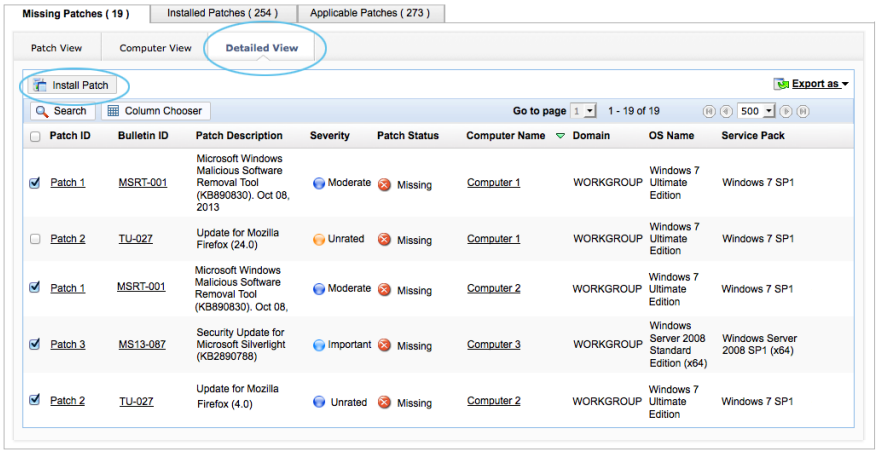
- SYN, RST Cookies, Micro Blocks, etc.
- Need to understand how attack is perpetrated
- Configure firewall to disallow incoming protocols or all traffic
  - This may not be a practical solution
- Disable forwarding of directed IP broadcast packets on routers



Denial of Services

How to Defend Against DoS Attack

- Maintain virus protection on all clients on your network
- Maintain operating system patches
- Establish policies for downloading software

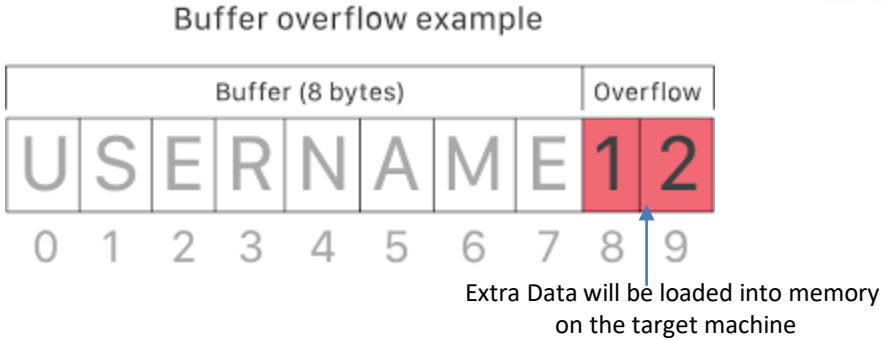


Buffer Overflow Attack

Defending Against Buffer Overflow Attacks

- More common than DoS a few years ago
- Still a very real threat
- Designed to put more information in the buffer than it is meant to hold
- Application design can reduce this threat
  More difficult to execute

- The graphic illustrates what happens in a Buffer overflow attack



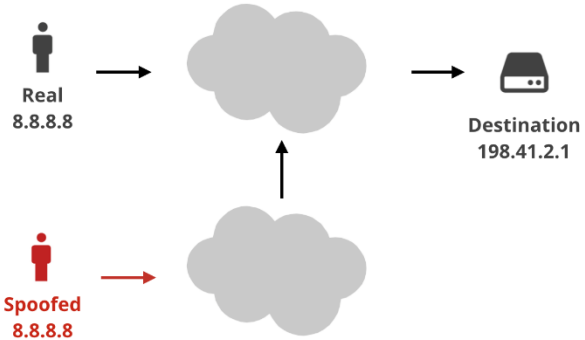
How do they occur?
What do Script viruses have to do with buffer overflows?
Read More at
https://www.cloudflare.com/learning/security/threats/buffer-overflow/

IP Spoofing

Defending Against IP Spoofing

The creation of Internet Protocol (IP) packets which have modified source address in order to hide the identity of the sender or impersonate another computer system or both.

- Used to gain unauthorized access to computers
- DDoS attacks will often utilize spoofing



How to defend ?

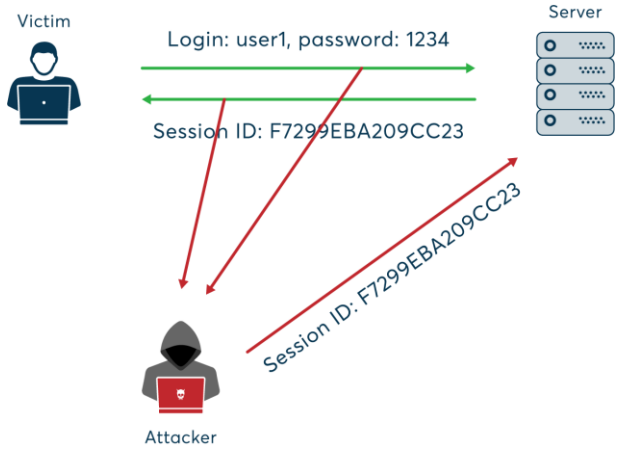
Packet filtering – examines incoming packets and looks at their source header, if don't match with their origin, the packets are rejected.

Session Hacking

Defending Against Session Hacking

- The hacker takes over a TCP session
- Most common is the “man-in-the-middle” Can also be done if the hacker gains access to the target machine

- Impact to Victims
  - Transfer money, buy item
  - Indeintity theft,
  - Change password and demanding ransom
  - Large Scale – can get access to company Single Sign On (SSO) applications



How to defend ?

Encryption is the only way to combat this type of attack – Use https to encrypt all session traffics



Summary

Most common network attacks:

- Session hacking
- Virus and Trojan horse attacks
- Denial of Service/Distributed Denial of Service
- Buffer overflow

- Explanation of how these attacks take place has been outlined



Summary

Basic defenses against these types of attacks

- Virus protection software
- Router configuration
- Smart e-mail policies and procedures
- Monitor network traffic
- Maintain a current patch policy to keep systems up to date with security patches

Prevent Denial of Service attacks

- Use of Proxy servers
- Established policies on maintenance
- Keep systems up to date with latest patches



Summary

Defend against Trojan horse and virus attacks:

- Have an established policy for email attachments and downloading software
- Do not open unknown attachments
- Strictly monitor software downloads and what can be downloaded
- Defend against buffer overflow attacks
- Routinely update systems
- Keep security patches up to date